

제주국제자유도시개발센터 상임감사

통 보

제 목 : 정보보안(개인정보 보호) 관련 계획 및 업무 수행 미흡

관계부서 : 정보관리실

내 용

1. 업무 개요

경영기획본부 정보관리실은 직제규정 시행세칙 제5조 관련 별표 1의 업무 분장에 따라 제주국제자유도시개발센터(이하 “센터”)의 정보화 및 정보보안, 개인정보 등의 업무를 총괄하고 있다.

2. 관계법령 및 판단기준

정보관리실은 정보화업무규정 제9조(정보화전략계획 수립)에 따라 2018년 7월 23일부터 2019년 2월 18일까지 439,900,000원의 예산을 사용하여 정보화·정보보안 전략계획 및 정보시스템 아키텍처 수립 용역을(이하 “용역”) 시행하고, 정보화/정보보안 비전 및 중장기(5개년) 전략계획을 수립하였다.

또한, 정보관리실은 업무분장 업무를 수행하는 데 있어 정보보호 및 개인정보보호 관계법령과 내부 정보보안업무지침 및 제주국제자유도시개발센터 개인정보보호 세부 지침을 준수하여야 한다.

3. 감사결과 확인된 문제

가. 정보보안(개인정보 보호) 관련 계획 미흡

위 용역을 통해 도출된 정보화/정보보안 비전 및 중장기(5개년) 전략의 이행과제별 로드맵은 아래와 같으며, 2019년과 2020년 중 추진할 과제로 23개 과제가 계획되어 있다.

		2019				2020				2021				2022				2023			
		1Q	2Q	3Q	4Q	1Q	2Q	3Q	4Q	1Q	2Q	3Q	4Q	1Q	2Q	3Q	4Q	1Q	2Q	3Q	4Q
핵심 Quick Win 과제	111 정보보안 정책 지침 제·개정	정보보호 정책 지침 제·개정			정보보호 인력보강					정보보호 정책 지침 제·개정				정보보호 정책 지침 제·개정							정보보호 정책 지침 제·개정
	121 인적 보안 강화	인적보안 관리 체계 정립																			
	122 외부자 보안 강화			외부 용역자 통제시스템 구축								외부 용역자 통제시스템 구축				외부 용역자 통제 사무실 개조(서울)				외부 용역자 통제 사무실 개조(제주)	
	211 패치관리 자동화	패치관리 시스템 도입																			
	212 모바일 기기 보안									통합 모바일 관리 시스템 도입											
	213 서버 보안 강화					Secure OS 도입															
	221 복합기 사용 보안 강화					복합기 관리 시스템 도입															
	222 출력물에 대한 책임추적성 강화	DRM 상역면 업그레이드		필터링 솔루션 도입(선택적)																	
	311 침해사고 대응 체계 강화			침해 사고 대응 체계 강화																	
	312 사이버 보안 관제 센터 구축			사이버 보안 관제 센터 구축		사이버 보안 관제 센터 운영															
411 업무 연속성 체계 구축	업무 연속성 체계 강화																				
511 GDPR 대응 체계 강화	개인정보 처리활동 기록 관리 강화													DPO 인력 충원							

		2019				2020				2021				2022				2023			
		1Q	2Q	3Q	4Q	1Q	2Q	3Q	4Q	1Q	2Q	3Q	4Q	1Q	2Q	3Q	4Q	1Q	2Q	3Q	4Q
Quick Win 과제	131 정보보안 관리체계 인증 컨설팅											ISMS-수 인증 컨설팅				ISMS-수 인증 심사					
	531 개인정보 라이프 사이클 관리					개인정보 라이프 사이클 관리 시스템 도입															
중장기 기술 과제	421 재해복구 대응 체계 수립	재난관리 조직체계 구축, 재해복구 대응 절차 수립																			
	112 정보보안 조직체계의 정비	인적 보안 관리 체계 정립																			
	214 정보보안 진단 강화													보안 진단 시스템 도입							
	215 모의해킹 자동화 솔루션 도입															모의 해킹 자동화 솔루션 도입					
	216 정보보호 포털 구현																				정보보호 포털 구현
	532 개인정보 유출방지 강화												개인정보 유출 방지 강화								
	541 스마트 선별관제 시스템 도입 및 운영	물리적, 관리적 보호조치 강화				GDPR, GDPR 강화 조항, 유출방지 강화										스마트 선별 관제 시스템 도입					
전략적 실행 영역	113 정보보안 점검 활동 강화													주기적 정보보호 점검							
	431 재해복구 시스템 구축 방안 마련					재해복구 시스템 구축															
	512 개인정보관리 책임자(DPO, Data Protection Officer) 지정 및 제도 개선															DPO 인력 충원					
	513 개인정보 영향평가 수행					개인정보 영향평가 수행															
	521 개인정보 비식별 방안																개인정보 비식별 솔루션 도입				

그러나 정보관리실의 2019년, 2020년 정보보안(개인정보 보호 포함) 사업 계획을 보면 위 용역을 통해 수립한 중장기 전략계획의 이행과제 23개 중 대부분이 아래와 같이 누락되었다.

구분	2019년도	2020년도	검토의견
Quick Win 과제	정보보호정책 지침 제·개정	정보보호 인력보강	보안업무규정, 정보보안지침 작성함
	정보보호정책 지침 제·개정	정보보호정책 지침 제·개정	
	인적 보안 관리체계 정립	-	-
	외부용역자 관리시스템 구축	-	연간 업무추진계획에 누락

구분	2019년도	2020년도	검토의견
	패치 관리시스템 도입	-	연간 업무추진계획에 누락
	-	Secure OS 도입	연간 업무추진계획에 누락
	-	프린터 관리시스템 도입	연간 업무추진계획에 누락
	DRM 상위버전 업그레이드	-	문서보안 및 DB 접근 제어 솔루션 교체/도입
	워터마킹 솔루션 도입(선택적)	-	연간 업무추진계획에 누락
	침해사고 대응체계 강화	-	-
	사이버보안 관제센터 구축	사이버보안 관제센터 구축	사이버보안 관제 강화를 위한 자체 보안관제센터 설립
	업무 연속성 체계 강화	-	-
	개인정보 처리 활동 기록 유지·관리	-	개인정보 강화를 위한 유출 차단 및 검색 솔루션 교체
	-	개인정보 라이프 사이클 관리시스템 도입	개인정보 접속기록 관리솔루션 도입
중장기 기술 과제	재난관리 조직체계 구성, 재해복구 대응 절차 수립	-	연간 업무추진계획에 누락
	인적 보안 관리체계 정립	-	-
	물리적, 관리적 프로세스 정립	-	기관 출입 보안관리 기관 내 상시 보안 관리체계 구축
선택 과제	-	CCTV UTP 방식 전환, 유지보수 단일화	연간 업무추진계획에 누락
	-	재해복구 시스템 구축	연간 업무추진계획에 누락
	-	개인정보 영향평가 수행	개인정보보호 영향평가 용역

이와 같이, 중장기 전략계획의 이행과제가 연간 사업 계획에 반영이 안 되면 중장기 전략계획 이행과제의 이행 완료가 불투명하고 효과적인 업무 수행을 위해 진행한 위 용역의 효과가 없게 된다.

나. 정보보안 업무 수행 미흡

1) 보안 관련 규정 미비

정보보안 관련 행정안전부 개인정보 보호법 시행령 제30조(개인정보의 안전성 확보 조치) 제1항 제2호에 따르면 개인정보에 대한 접근 통제 및 접근 권한의 제한 조치를 하여야 한다고 되어 있으며,

개인정보 보호법 해설서에 해당 조치의 방법으로 비밀번호는 구성 문자의 종류에 따라 최소 10자리 또는 8자리 이상의 길이로 구성하여야 한다고 되어 있다.

그러나 정보보안지침 제77조(비밀번호 관리) 제1항에 따르면 개별사용자 및 정보시스템 관리자는 각종 비밀번호를 다음 각호에 해당하는 사항을 반영하고 숫자·문자·특수문자 등을 혼합하여 안전하게 설정하고 정기적으로 변경·사용하여야 한다고만 규정하고 있다.

이와 같이, 비밀번호 설정과 관련하여 관련 법령 등을 준용하지 않은 상황에서 보안사고가 발생 시 비밀번호 관리 부실로 센터의 보안업무 평가 등에 악영향을 줄 수 있다.

2) 계정 관리 미비

정보보안지침 제57조(로그기록 유지) 제4항에 따르면 정보시스템 관리자는 로그기록을 정기적으로 점검하고 점검 결과 비(非)인가자의 접속 시도, 자료의 위·변조 및 삭제 등 의심스러운 정황이나 위반한 사실을 발견한 경우 즉시 정보관리실장에게 통보하여야 한다고 규정하고 있다.

그러나 정보시스템의 효율적인 통제·관리를 위해 계정 권한 관리 및 점검은 이루어지고 있으나 정보시스템 접근기록에 대한 주기적 점검은 수행되지 않고 있다.

이로 인해 비인가자에 대한 정보시스템 접속 시도 및 과도한 정보 접근 등 정보보안 취약점이 발생할 우려가 있다.

3) 비밀번호 관리 소홀

정보보안지침 제55조(서버 보안) 및 제77조(비밀번호 관리)에 따르면 서버는 보안을 위해 접근 통제 및 권한 차등 부여 등 철저한 보안 조치를 비롯하여 비밀번호 관리도 적절하게 이루어져야 한다.

그러나 정보관리실 내부문서인 장애 대응 시나리오 내용 중 정보시스템 서버 관련 비밀번호가 포함되어 있어 보안사고 발생위험이 크다.

【관계부서 의견】

정보관리실은 감사 결과를 이견 없이 수용하고 정보보안(개인정보 보호 포함) 업무에 취약점이 발생하지 않도록 만전을 기하겠다는 의견을 제시하였다.

【조치할 사항】 이사장은

정보보안(개인정보 보호 포함) 관련 계획을 중장기 정보화/정보보안 전략을 반영하여 수립하시고 정보보안지침 상 비밀번호 설정 관련 사항 등을 적절하게 반영하시기 바랍니다. [통보 : 정보관리실]